



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



Review intake draft: CVE-2026-45467 Microsoft SharePoint Server Spoofing Vulnerability

Vulnerability Report

Classification	TLP:CLEAR
Published	2026-06-10
Version	1.0
Author	Lost Boys Cyber
Report Type	Vulnerability Report

TLP:CLEAR | Lost Boys Cyber | Review intake draft: CVE-2026-45467 Microsoft SharePoint Server Spoofing Vulnerability - Vulnerability Report

Published: 2026-06-10 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Intelligence Requirement
3. Source Review and Confidence
4. Key Findings
5. Threat Context
6. Detection and Hunting
7. Recommendations
8. References

1. Executive Summary

CVE-2026-45467 is a medium-severity Microsoft SharePoint Server spoofing vulnerability rooted in `CWE-79` cross-site scripting behavior. Microsoft, the CVE Program CNA record, and NVD align that an authorized attacker can exploit improper neutralization of input during web page generation in Microsoft Office SharePoint to perform spoofing over a network. The published CVSS v3.1 vector is `AV:N/AC:L/PR:L/UI:R/S:U/C:L/I:L/A:N`, which frames the issue as a network-reachable attack that still requires low privileges and a user interaction event.

The most important operational nuance is that this is not being described publicly as an unauthenticated remote-code-execution issue. The available record instead supports a more targeted abuse model in which a low-privilege SharePoint user injects or submits malicious web content that is later rendered to another user in a trusted SharePoint context. In practice, that makes the likely defensive concern session theft, credential capture, in-portal phishing, or trusted-workflow impersonation inside collaboration sites rather than direct server takeover from the internet.

Exposure is concentrated on on-premises SharePoint estates: SharePoint Enterprise Server 2016, SharePoint Server 2019, and SharePoint Server Subscription Edition below the fixed versions Microsoft and the CNA record published on 2026-06-09. No reviewed authoritative source confirmed public exploitation, public disclosure before patch release, or CISA KEV inclusion at assessment time. Even so, SharePoint often sits in high-trust internal business workflows, so organizations should prioritize patching, review recent authenticated content changes by low-privilege users, and hunt for suspicious script-like input reaching collaboration pages and `\_layouts` endpoints.

2. Intelligence Requirement

This review addresses the following intelligence requirement: what is `CVE-2026-45467`, which SharePoint deployments are exposed, what does the public record say about exploitation status and likely attack paths, and what should defenders do immediately to reduce enterprise risk?

Question	Assessment
What is the vulnerability?	A SharePoint spoofing issue caused by improper neutralization of input during web page generation, mapped publicly to `CWE-79` cross-site scripting.
What access does an attacker need?	Microsoft describes the attacker as authorized; the CVSS vector also requires low privileges.
Is user interaction required?	Yes. The reviewed CVSS v3.1 vector includes `UI:R`, supporting a model where another user must view or interact with malicious SharePoint-rendered content.
What is the most likely impact?	Spoofed SharePoint content, credential/session theft opportunities, or trusted-portal phishing against other users.
Which products are affected?	SharePoint Enterprise Server 2016, SharePoint Server 2019, and SharePoint Server Subscription Edition below the fixed versions listed in Section 4.
Is there confirmed active exploitation?	No reviewed authoritative source confirmed in-the-wild exploitation, prior public disclosure, or KEV inclusion as of 2026-06-10.
What matters most to defenders?	Patch exposed SharePoint farms, review authenticated content-edit paths, monitor IIS/ULS/audit telemetry for script-like payloads, and hunt for suspicious low-privilege user activity targeting collaboration pages.

3. Source Review and Confidence

Source	Contribution	Confidence
Microsoft Security Update Guide entry	Canonical Microsoft vulnerability description and primary remediation landing page.	High
Microsoft June 2026 CVRF document	Confirms severity, exploitability assessment, affected products, and remediation KB identifiers by product family.	High
CVE Program CNA API record	Confirms `CWE-79`, publication timing, fixed version ranges, affected products, and CVSS v3.1 vectoring.	High
NVD JSON 2.0 / detail page	Corroborates Microsoft description, severity, and vulnerability metadata in a normalized public record.	High
Zero Day Initiative June 2026 review	Corroborates Microsoft's June 2026 SharePoint vulnerability cluster and shows this CVE as Important / 4.6 with no public-exploitation flag in the review table.	Medium
Rapid7 June 2026 Patch Tuesday analysis	Corroborates Microsoft's exploitation-likelihood assessment and broader SharePoint patch context.	Medium
CISA Known Exploited Vulnerabilities feed	Negative-evidence check only: `CVE-2026-45467` was not present in the reviewed KEV JSON snapshot dated 2026-06-10.	Medium

Confidence is high on the vulnerability's existence, affected product families, fixed version thresholds, severity, and the absence of public exploitation confirmation at review time because those details are directly supported by Microsoft, the CNA record, NVD, and Microsoft's CVRF release. Confidence is lower on the exact injection point, whether the flaw is stored versus reflected in specific workflows, and the most reliable exploit telemetry because the reviewed public sources do not publish proof-of-concept code, endpoint-specific request patterns, or a detailed root-cause narrative. Detection guidance in this report therefore emphasizes exposure management, suspicious authenticated content activity, and script-pattern hunting rather than claiming a single exploit-specific signature.

4. Key Findings

4.1 Core Vulnerability Metadata

Field	Value
CVE	`CVE-2026-45467`
Vulnerability name	`Microsoft SharePoint Server Spoofing Vulnerability`
Product / component	Microsoft Office SharePoint / on-premises SharePoint Server web content rendering paths
Weakness	`CWE-79` Improper Neutralization of Input During Web Page

	Generation (`Cross-site Scripting`)
Severity	`4.6 / MEDIUM` (CVSS v3.1)
CVSS v3.1 vector	`AV:N/AC:L/PR:L/UI:R/S:U/C:L/I:L/A:N`
Attack vector	Network
Privileges required	Low / authorized attacker
User interaction	Required
Confidentiality impact	Low
Integrity impact	Low
Availability impact	None
Publication date	`2026-06-09`
Microsoft exploitability assessment	`Exploitation Less Likely`
Public disclosure before patch	No reviewed authoritative source confirmed public disclosure before release
Exploitation status at review time	No reviewed authoritative source confirmed in-the-wild exploitation or KEV inclusion

4.2 Affected Product and Fix Matrix

Product family	Vulnerable versions	Fixed version threshold	Microsoft remediation
SharePoint Enterprise Server 2016	`16.0.0` through versions below `16.0.5556.1005`	`16.0.5556.1005` or later	`KB5002880`
SharePoint Server 2019	`16.0.0` through versions below `16.0.10417.20153`	`16.0.10417.20153` or later	`KB5002874`
SharePoint Server Subscription Edition	`16.0.0` through versions below `16.0.19725.20384`	`16.0.19725.20384` or later	`KB5002873`

These fixed-version thresholds are drawn from the CNA record and corroborated by Microsoft's June 2026 CVRF remediations. Organizations using farm-level patching, deferred CU rollouts, or mixed-version SharePoint estates should verify every web front end and application server individually rather than assuming farm homogeneity.

4.3 Analyst Findings

- The reviewed public record best supports a trusted-workflow abuse scenario rather than direct server compromise. An authenticated low-privilege user is the likely entry point, and user interaction is required for impact to materialize.
- Because the weakness class is `CWE-79`, the most realistic business risks are phishing-like spoofing inside a trusted SharePoint site, credential or token theft from users viewing malicious content, or manipulation of business workflows that rely on SharePoint pages, forms, and collaboration artifacts.
- SharePoint frequently operates as an internal high-trust collaboration platform. That means a medium CVSS score can still translate into meaningful enterprise risk when the affected farm is used for HR, finance, legal, engineering, or administrative processes.

- The June 2026 patch cycle included multiple SharePoint spoofing issues alongside higher-severity SharePoint EoP and RCE entries. Defenders should treat `CVE-2026-45467` as part of a broader SharePoint hardening and review effort rather than an isolated one-off fix.
- No public IOC set, exploit sample, or named threat-actor reporting was identified during this review. Defenders should avoid overstating active exploitation while still treating unpatched authenticated content paths as a meaningful opportunity for internal phishing and impersonation.

5. Threat Context

The most plausible attack paths for `CVE-2026-45467` begin with a valid SharePoint account that has enough access to create, edit, upload, or otherwise influence content rendered to other users. That access could come from a compromised employee account, contractor credentials, a malicious insider, or a threat actor who first obtains low-privilege access through credential phishing, password spraying, VPN compromise, or compromise of another internal application.

Once inside SharePoint, the attacker likely attempts to place or submit crafted script-bearing content in a location that other users will trust and visit. Because the public record explicitly maps the issue to cross-site scripting and requires user interaction, the likely downstream objectives are browser-side: credential harvesting, session hijacking, in-portal redirection, fake approval prompts, or impersonation of trusted collaboration content. If the victim has privileged access to the SharePoint farm or adjacent Microsoft ecosystems, the resulting blast radius can exceed the low CVSS score.

Public reporting reviewed for this task does not show confirmed exploitation in the wild. Microsoft's June 2026 CVRF lists `Publicly Disclosed: No; Exploited: No; Latest Software Release: Exploitation Less Likely` for this CVE. ZDI and Rapid7 both reflected comparable June 2026 table entries for this SharePoint spoofing issue, and the reviewed CISA KEV feed did not include `CVE-2026-45467` as of 2026-06-10. Those are time-bounded observations rather than guarantees against future weaponization.

The strongest ATT&CK-aligned mappings supported by the public record are:

Tactic	Technique	Relevance
Initial Access / Execution	`T1189` Drive-by Compromise	Best-fit browser-side mapping when malicious SharePoint-rendered content executes in a victim's browser after they browse to trusted collaboration content.
Credential Access / Collection	`T1056` Input Capture or `T1539` Steal Web Session Cookie	These are plausible follow-on outcomes of successful script execution in a SharePoint session, but they are impact-oriented inferences rather than directly confirmed exploit steps.
Defense Evasion / Masquerading	`T1036` Masquerading	Relevant only at a high level because the vulnerability is publicly described as spoofing, but the reviewed source set does not justify a narrower sub-technique assignment with high confidence.

Higher-risk exposure patterns include internet-exposed or externally federated SharePoint deployments, collaboration sites editable by broad user populations, document portals used for approvals or finance workflows, and farms where privileged administrators routinely browse user-controlled content. Lower-risk environments are those fully patched to the fixed versions above, with tightly scoped author permissions, strong authentication, and compensating controls that reduce untrusted active content rendering.

6. Detection and Hunting

Because the reviewed public record does not disclose the exact request path or payload pattern that triggers the flaw, the most defensible detection strategy is layered:

- identify SharePoint farms and servers still below the fixed version thresholds
- review authenticated content-edit and page-render telemetry for script-like input patterns
- monitor for suspicious IIS requests to collaboration pages and `\_layouts` paths containing encoded HTML or JavaScript indicators
- investigate browser-side follow-on activity such as unexpected redirects, token reuse, credential prompts, or anomalous privileged actions after low-privilege content edits
- prioritize retrospective review on sites that remained unpatched after the 2026-06-09 release

6.1 Detection Logic Summary

Signal	Telemetry Source	Analytic Goal
SharePoint servers below the fixed product versions in Section 4	CMDB / vulnerability management / SharePoint farm inventory	Identify exposure and remediation gaps
Authenticated requests with encoded script markers such as `%3Cscript`, `javascript%3A`, `onerror%3D`, or ` <img` `<svg`="" data<="" form="" fragments="" in="" or="" payload="" query="" strings="" td=""><td>IIS logs, WAF logs, reverse-proxy logs, application telemetry</td><td>Surface likely exploitation attempts or payload staging</td></img`>	IIS logs, WAF logs, reverse-proxy logs, application telemetry	Surface likely exploitation attempts or payload staging
Bursts of page, list, wiki, or form edits by low-privilege users followed by views from more privileged users	SharePoint audit logs, ULS logs, Microsoft 365 audit where integrated	Identify content-seeding activity intended to target higher-trust victims
Browser sessions that hit SharePoint and then show unusual redirects, suspicious authentication prompts, or rapid token/session reuse	Proxy logs, identity telemetry, EDR browser telemetry	Identify probable post-XSS account or session abuse
Unusual requests to `_layouts/15/`, list forms, site pages, classic pages, or document metadata edit paths with HTML/JS-heavy parameters	IIS logs, WAF logs, ULS logs	Focus review on likely rendering surfaces

Analyst caveat: the public sources reviewed here do not prove that every malicious request will expose the same strings or the same endpoint family. The examples below should be treated as practical hunt pivots for SharePoint XSS-style abuse, not deterministic exploit signatures.

6.2 Example Sigma Logic

<pre> title: Suspicious SharePoint XSS-Like Request Patterns in Web Logs id: 9f38d530-4546-4f67-8c45-sharepoint-xss-hunt status: experimental description: Hunts for encoded script or event-handler markers in SharePoint-related web requests that may merit review during CVE-2026-45467 investigations. logsource: product: webserver service: iis detection: selection_uri: cs-uri-stem contains: - '/_layouts/' - '/SitePages/' - '/Lists/' - '/Forms/' selection_payload: cs-uri-query contains: - '%3Cscript' - 'javascript%3A' </pre>
--

```

- '%3Conerror%3D'
- '%3Cimg'
- '%3Csvg'
condition: selection_uri and selection_payload
falsepositives:
- benign developer testing or security validation in non-production SharePoint environments
- encoded content in custom workflows that legitimately store HTML fragments
level: medium

```

6.3 Example Hunt Queries

Exposure inventory query:

```

DeviceTvmSoftwareInventory
| where SoftwareName has "SharePoint"
| project DeviceName, SoftwareName, SoftwareVersion, EndOfSupportStatus
| order by DeviceName asc

```

Suspicious SharePoint request-pattern query:

```

W3CIISLog
| where TimeGenerated > ago(30d)
| where csUriStem has_any ("/_layouts/", "/SitePages/", "/Lists/", "/Forms/")
| where csUriQuery has_any ("%3Cscript", "javascript%3A", "%3Conerror%3D", "%3Cimg", "%3Csvg")
| project TimeGenerated, Computer, cIP, csMethod, csUriStem, csUriQuery, csUserName, scStatus,
csUserAgent
| order by TimeGenerated desc

```

SharePoint audit / page-edit hunt query:

```

OfficeActivity
| where TimeGenerated > ago(30d)
| where OfficeWorkload =~ "SharePoint"
| where Operation has_any ("PageViewed", "PageModified", "FileModified", "FileAccessed", "ListUpdated")
| where UserId !contains "svc_"
| project TimeGenerated, UserId, Operation, Site_Url, SourceFileName, ClientIP, UserAgent
| order by TimeGenerated desc

```

6.4 Suggested Hunt Questions

- Which SharePoint 2016, 2019, and Subscription Edition farms remained below the fixed versions after 2026-06-09?
- Do low-privilege users show unusual bursts of edits or uploads to site pages, classic pages, lists, or forms shortly before privileged users browse the same locations?
- Do IIS or WAF logs contain encoded script markers or JavaScript URI patterns in SharePoint-targeted requests?
- After suspicious SharePoint views, do affected user sessions show unusual redirects, repeated authentication prompts, or rapid reuse from new IPs or user agents?
- Are there sites with broad author permissions where business-critical approvers, administrators, or executives routinely browse user-controlled content?

7. Recommendations

Priority	Owner	Action
Critical	SharePoint Platform / Infrastructure	Apply the June 2026 SharePoint updates and verify every farm member is at or above the fixed versions in Section 4.
Critical	Vulnerability Management	Inventory all on-premises SharePoint 2016, 2019, and Subscription Edition deployments and confirm that legacy or secondary farms were not missed during patching.

High	SharePoint Administrators	Review which users and groups can create or edit pages, lists, forms, and rich-content areas; reduce broad author permissions where possible.
High	SOC / Detection Engineering	Add temporary detections for script-like request markers in SharePoint IIS, proxy, and WAF logs; retain logs long enough for retrospective review.
High	Identity / IAM	Prioritize MFA coverage, session-monitoring, and anomaly review for accounts that administer SharePoint or regularly approve sensitive workflows through it.
High	Incident Response	If suspicious content activity is found on unpatched farms, review for browser-side theft outcomes including stolen session cookies, malicious redirects, and follow-on credential use.
Medium	Security Architecture	Place internet-exposed SharePoint behind WAF inspection where feasible and tune rules to alert on encoded script or JavaScript URI patterns.
Medium	Threat Intelligence	Re-check Microsoft advisories, KEV, and public exploit reporting in subsequent patch cycles in case exploitation status changes after the initial publication window.

Additional analyst guidance:

- Treat this issue as more than a routine medium-severity score when SharePoint is embedded in privileged internal workflows or exposed to partner/external collaboration.
- Because the public record does not reveal a stable exploit fingerprint, pair detection content with site-permission review and patch verification rather than relying only on signatures.
- If patching must be delayed, narrow authoring permissions, increase monitoring on content-edit paths, and consider temporary approval gates for pages or forms that render user-supplied content.

8. References

- Microsoft Security Update Guide: <https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-45467>
- Microsoft Security Response Center CVRF, June 2026 Security Updates: <https://api.msrc.microsoft.com/cvrf/v3.0/cvrf/2026-Jun>
- CVE Program CNA API record: <https://cveawg.mitre.org/api/cve/CVE-2026-45467>
- NVD detail page: <https://nvd.nist.gov/vuln/detail/CVE-2026-45467>
- NVD JSON 2.0 API query: <https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2026-45467>
- Zero Day Initiative, The June 2026 Security Update Review: <https://www.zerodayinitiative.com/blog/2026/6/9/the-june-2026-security-update-review>
- Rapid7, Patch Tuesday June 2026: <https://www.rapid7.com/blog/post/em-patch-tuesday-june-2026/>
- CISA Known Exploited Vulnerabilities JSON feed: https://www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json